

Google Cloud Platform

Three-Tier Application Platform

Architecture & Security Compliance Documentation

Document	Project Design, Compliance & Deployment Reference
Version	3.0 (Modular, Hardened, Deployed & Validated)
Platform	Google Cloud Platform
IaC	Terraform (8 modules)
Status	Deployed to GCP; smoke-tested with live workloads
Classification	Confidential — Internal Use

Compliance frameworks referenced: CIS GCP Foundations Benchmark v2.0, ISO/IEC 27001:2022, SOC 2 (Trust Services Criteria), PCI-DSS v4.0.

Table of Contents

1. Executive Summary
2. Architecture Overview
3. Module Design
4. Network Architecture
5. Identity & Access Management
6. Data Protection & Encryption
7. Edge Security (Cloud Armor / WAF)
8. Logging, Monitoring & Audit
9. Security Compliance Mapping
10. Deployment Guide
11. Operations, HA & Disaster Recovery
12. Risk Register & Roadmap
13. Game Hosting — Infrastructure Extensions
14. Deployed Game Platforms (WorkAdventure & Cloud-Morph)
15. Deployment Notes & Operational Lessons

1. Executive Summary

This document describes the architecture and security posture of a three-tier application platform deployed on Google Cloud Platform (GCP) and provisioned entirely through modular Terraform. The platform separates the presentation (frontend), application (backend) and data (database) tiers into isolated network segments, each with dedicated identity, autoscaling and health management, fronted by a global HTTPS load balancer protected by a Cloud Armor Web Application Firewall.

The design was refactored from a flat, single-directory Terraform configuration into seven reusable modules, and hardened to meet production-grade security and compliance objectives. Encryption with customer-managed keys (CMEK), least-privilege identity, private-only data access, default-deny networking, and centralized audit logging are applied throughout.

Key outcomes

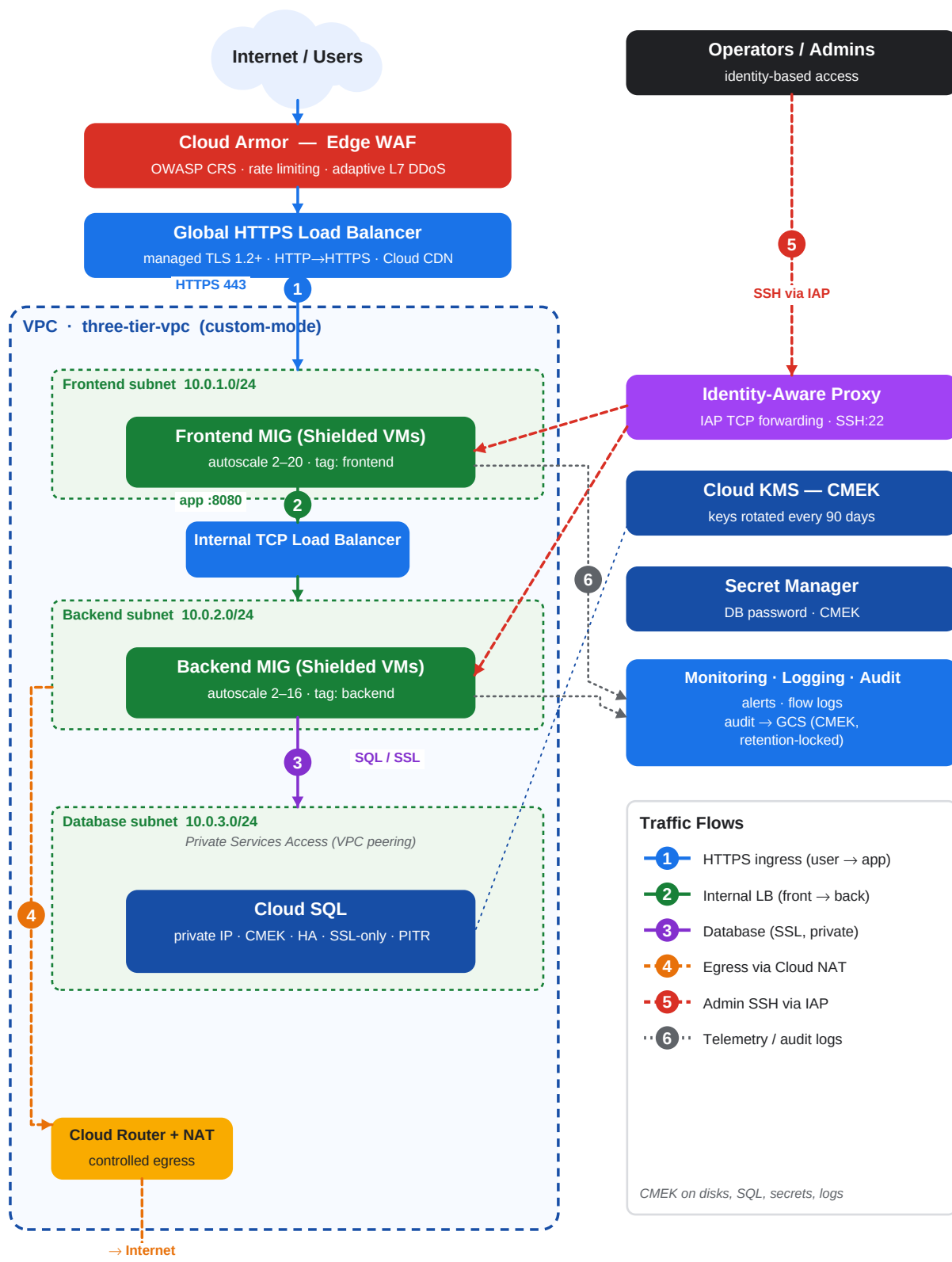
- **Modular & reusable:** a single generic compute module powers both application tiers; environments are driven by tfvars (dev/prod).
- **Encryption everywhere:** CMEK on disks, Cloud SQL, Secret Manager and the log archive bucket, with automatic 90-day key rotation.
- **Reduced attack surface:** no public IPs on instances, IAP-only SSH, default-deny firewall, and private-only Cloud SQL.
- **Edge protection:** Cloud Armor with OWASP Core Rule Set, per-client rate limiting and adaptive (ML) layer-7 DDoS defense.
- **Provable compliance:** controls mapped to CIS GCP, ISO 27001, SOC 2 and PCI-DSS (Section 9).
- **Deployed & validated:** provisioned to a live GCP project and smoke-tested with real workloads — nginx, Jenkins-in-Docker, and two containerised game platforms on a dedicated VM (Sections 13–14).

Notable fixes applied during hardening

- Added **Cloud NAT** — the original design had neither public IPs nor NAT, so instances could not reach the internet to patch.
- Implemented **Cloud Armor**, which the original README described but never actually deployed.
- Removed a **duplicate KMS data source** that caused the original code to fail `terraform validate`.
- Replaced blanket `cloud-platform` trust with least-privilege IAM roles and enforced Shielded VM + OS Login.

2. Architecture Overview

Traffic flows from the internet through Cloud Armor and the global HTTPS load balancer to the frontend managed instance group. The frontend reaches the backend only through an internal load balancer; the backend reaches Cloud SQL only over a private, peered network path. Instances have no public IP and use Cloud NAT for controlled egress.



3. Module Design

The configuration is composed from the following modules under `modules/`. The composition root (`main.tf`) wires them together and expresses explicit dependencies (for example, API enablement before resource creation, and KMS IAM grants before Cloud SQL creation).

Module	Responsibility	Primary Security Controls
project-services	Enable required Google APIs with a propagation wait	Minimal explicit API set
networking	VPC, per-tier subnets, firewall, Cloud NAT, private services access	Default-deny ingress, flow logs, IAP-only SSH, Private Google Access, NAT egress
security	CMEK key ring & keys, per-tier service accounts, Cloud Armor	Key rotation, least-privilege IAM, OWASP WAF, adaptive DDoS, rate limiting
compute	Reusable tier: instance template, MIG, autoscaler, health check	Shielded VM, CMEK disks, no public IP, OS Login, blocked project SSH keys
load-balancer	External global HTTPS LB + internal LB	Managed TLS, MODERN policy (TLS 1.2+), HTTP→HTTPS redirect, Armor attach
database	Cloud SQL primary/replicas + password secret	Private IP, CMEK, SSL-only, PITR, deletion protection, hardened flags
monitoring	Alerts, notification channel, audit archive	Audit log sink to CMEK bucket, DATA_READ/WRITE audit logging
game-server	Dedicated single-host VM for stateful container workloads	Shielded VM, CMEK disk, IAP-only SSH, static IP, scoped web ports

Composition & dependency ordering

- project-services → (networking, security) → compute tiers → load-balancer → database → monitoring.
- The database waits on both the private-services peering connection and the Cloud SQL service agent's CMEK grant to avoid race conditions.

4. Network Architecture

Subnets (custom-mode VPC, regional)

Tier	Subnet	CIDR	Public IP	Egress
Frontend	<env>-frontend-subnet	10.0.1.0/24	None	Cloud NAT
Backend	<env>-backend-subnet	10.0.2.0/24	None	Cloud NAT
Database	<env>-database-subnet	10.0.3.0/24	None (private IP)	n/a

Firewall rules (default-deny posture, all logged)

Rule	Direction	Source	Target	Ports	Action
deny-all-ingress	Ingress	0.0.0.0/0	all	all	DENY (65534)
allow-frontend-from-lb	Ingress	GFE ranges	tag: frontend	80,443	ALLOW
allow-backend-from-frontend	Ingress	tag: frontend	tag: backend	8080,8443	ALLOW
allow-iap-ssh	Ingress	35.235.240.0/20	frontend,backend	22	ALLOW
allow-health-checks	Ingress	130.211.0.0/22, 35.191.0.0/16	frontend,backend	80,443,8080,8443	ALLOW

- **No SSH from the internet** — administrative access is via Identity-Aware Proxy TCP forwarding only.
- **Public clients never reach the VMs directly** — only Google Front End / health-check ranges may reach the frontend; end users transit the load balancer.
- **VPC Flow Logs** enabled on every subnet; **Private Google Access** lets private instances reach Google APIs without egress to the internet.
- **Cloud SQL** is reachable only through Private Services Access (VPC peering); no public IP is assigned.

5. Identity & Access Management

Each tier runs under a dedicated service account granted only the roles it needs. Legacy broad access scopes are replaced with fine-grained IAM roles. Human access to instances requires OS Login and IAP.

Principal	Roles	Rationale
frontend-sa	logging.logWriter, monitoring.metricWriter, monitoring.viewer	Emit logs/metrics only; no data access
backend-sa	+ cloudsql.client, secretmanager.secretAccessor	Connect to Cloud SQL & read the DB password secret
Cloud SQL agent	cloudkms.cryptoKeyEncrypterDecrypter (SQL key)	Envelope-encrypt the database with CMEK
Secret Mgr agent	cloudkms.cryptoKeyEncrypterDecrypter (secret key)	Encrypt secrets with CMEK
Compute agent	cloudkms.cryptoKeyEncrypterDecrypter (disk key)	Encrypt boot disks with CMEK

- Principle of least privilege enforced per tier.
- No user-managed service-account keys are created; workloads use attached identities.
- OS Login centralizes SSH authorization in IAM and ties access to org identity.

6. Data Protection & Encryption

All data at rest is encrypted with customer-managed keys (CMEK) in Cloud KMS, created in the deployment region and rotated automatically. Data in transit is protected by TLS at the edge and enforced SSL to the database.

Asset	At Rest	In Transit	Key / Rotation
Compute boot disks	CMEK	n/a	disk key / 90 days
Cloud SQL	CMEK	SSL enforced (ENCRYPTED_ONLY)	sql key / 90 days
Secret Manager	CMEK	TLS (API)	secret key / 90 days
Audit log bucket	CMEK	TLS (API)	storage key / 90 days
External traffic	n/a	TLS 1.2+ (MODERN policy)	Google-managed cert

- KMS crypto keys carry `prevent_destroy` to guard against accidental key loss (and data loss).
- The database password is randomly generated and stored only in CMEK-encrypted Secret Manager — never in plaintext state output.
- Cloud SQL enforces `ssl_mode = ENCRYPTED_ONLY` and IAM database authentication.

7. Edge Security (Cloud Armor / WAF)

The external backend service is protected by a Cloud Armor security policy attached at the global load balancer. The policy combines OWASP Core Rule Set signatures, per-client rate limiting, and adaptive layer-7 DDoS defense.

Priority	Rule	Action
1000	SQL injection (sqli-v33-stable)	deny(403)
1001	Cross-site scripting (xss-v33-stable)	deny(403)
1002	Local/Remote file inclusion (lfi/rfi)	deny(403)
1003	Remote code execution (rce-v33-stable)	deny(403)
2000	Per-IP rate limit (throttle/ban)	rate_based_ban → deny(429)
—	Adaptive Protection (L7 DDoS ML)	auto-detect
MAX	Default	allow

8. Logging, Monitoring & Audit

- **Cloud Audit Logs:** Admin Activity plus DATA_READ and DATA_WRITE data-access logs enabled for all services.
- **Log sink:** all `cloudaudit.googleapis.com` logs exported to a dedicated, versioned, retention-locked GCS bucket encrypted with CMEK.
- **VPC Flow Logs** and **firewall logging** provide network visibility.
- **Load balancer and health-check logging** enabled at 100% sample rate.
- **Cloud Monitoring:** high-CPU alert policy with email notification channel; auto-close after 30 minutes.
- **Cloud SQL Query Insights** enabled for performance and anomaly analysis.

The retention-locked bucket supports tamper-evident, WORM-style audit retention (default 365 days in prod), satisfying evidence-retention requirements for the frameworks in Section 9.

9. Security Compliance Mapping

9.1 CIS Google Cloud Platform Foundations Benchmark

CIS Ref	Control	Implementation
2.x	Logging & monitoring	Audit log sink, data-access logs, flow logs
3.1	Default network not used	Custom-mode VPC, no default network
3.6/3.7	No open SSH/RDP to 0.0.0.0/0	IAP-only SSH; default-deny ingress
3.9	VPC Flow Logs enabled	Enabled on all subnets
4.x	VM hardening	Shielded VM, OS Login, no public IP, serial off
6.x	Cloud SQL hardening	Private IP, SSL-only, CMEK, secure flags
1.x	IAM least privilege	Per-tier SAs, scoped roles, no SA keys

9.2 ISO/IEC 27001:2022 (Annex A)

Control	Theme	Implementation
A.5.15	Access control	Least-privilege IAM, IAP, OS Login
A.8.24	Use of cryptography	CMEK at rest, TLS in transit, key rotation
A.8.20	Network security	Segmented subnets, default-deny firewall, NAT
A.8.16	Monitoring activities	Audit logs, alerts, flow logs
A.8.15	Logging	Centralized, CMEK, retention-locked archive
A.8.7	Protection against malware	WAF/Cloud Armor OWASP rules

9.3 SOC 2 (Trust Services Criteria)

TSC	Criterion	Implementation
CC6.1	Logical access	IAM least privilege, IAP, service accounts
CC6.6	Boundary protection	WAF, LB, default-deny firewall, private DB
CC6.7	Encryption of data	CMEK at rest; TLS/SSL in transit
CC7.2	Detection & monitoring	Audit logs, alerts, adaptive DDoS
A1.1	Availability	Regional HA (MIG + Cloud SQL REGIONAL), autoscaling

9.4 PCI-DSS v4.0 (illustrative)

Req	Requirement	Implementation
1	Network security controls	Segmentation, default-deny, private DB
3	Protect stored data	CMEK encryption; secrets in Secret Manager
4	Encrypt transmission	TLS 1.2+ at edge; SSL-only to DB
6	Secure systems/software	WAF, hardened images, IaC review
8	Identify & authenticate	IAM, OS Login, IAM DB auth
10	Log & monitor access	Audit logs to WORM archive; monitoring

Mappings are indicative of control coverage provided by the infrastructure layer; full certification requires organizational controls, evidence collection and independent assessment.

10. Deployment Guide

Prerequisites

- Terraform $\geq 1.3.0$ and the Google Cloud SDK authenticated (`gcloud auth application-default login`).
- A GCP project with billing enabled and appropriate admin permissions.
- A GCS bucket for remote state (recommended; versioned + CMEK).

Steps

Initialize (prod remote state)

```
terraform init -backend-config=environments/prod.gcs.tfbackend
```

Plan

```
terraform plan -var-file=environments/prod.tfvars
```

Apply

```
terraform apply -var-file=environments/prod.tfvars
```

Destroy (non-prod)

```
terraform destroy -var-file=environments/dev.tfvars
```

Environments are parameterized via `environments/*.tfvars`. Prod enables HTTPS (managed cert), Cloud CDN, regional HA Cloud SQL, read replicas and deletion protection.

11. Operations, HA & Disaster Recovery

High availability

- Regional managed instance groups spread across three zones with autoscaling and auto-healing.
- Cloud SQL REGIONAL availability (synchronous standby) in prod; optional read replicas.
- Global HTTPS load balancer with health-checked backends and Cloud CDN.

Backup & recovery

- Automated Cloud SQL backups (retained 30 in prod) plus binary-log point-in-time recovery.
- Versioned, retention-locked audit archive bucket.
- Rolling, zero-downtime instance-template updates (PROACTIVE, surge, substitute).

Administrative access

```
gcloud compute ssh <instance> --zone <zone> --tunnel-through-iap
```

12. Risk Register & Roadmap

The current baseline addresses the major infrastructure risks. The following items are recommended to reach a fully certified posture:

Area	Recommendation	Priority
Perimeter	Adopt VPC Service Controls to prevent data exfiltration	High
Org policy	Enforce org policies (no external IP, restrict SA key creation, uniform bucket access)	High
Supply chain	Enable Binary Authorization for container workloads	Medium
Threat detection	Enable Security Command Center Premium	High
Egress	Tighten Cloud NAT to specific subnets; add egress firewall rules	Medium
Secrets	Rotate DB credentials automatically via scheduled function	Medium
CI/CD	Add tfsec/Checkov + OPA policy gates to the pipeline	Medium
State	Confirm remote state bucket has versioning, CMEK and restricted IAM	High

13. Game Hosting — Infrastructure Extensions

The platform was deployed to a live GCP project and validated end-to-end by running real workloads across every tier (Table 13.1), including two interactive game platforms. Rather than repurpose the autoscaled tiers, the infrastructure was extended with a dedicated, single-host game server in the same project and VPC — keeping the hardened tiers stateless and untouched.

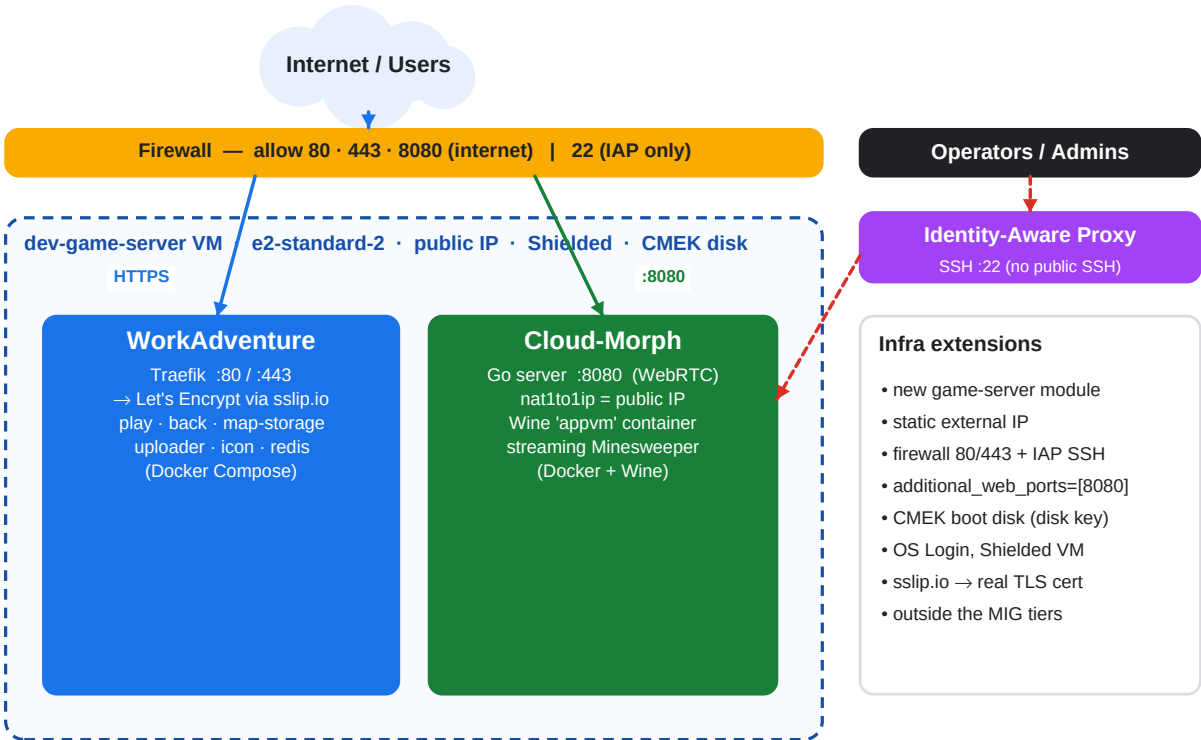
Table 13.1 — Deployed workloads

Host / Tier	Workload	Access	Status
Frontend MIG	nginx static site	Global HTTPS LB (public IP)	Live — 200
Backend MIG	Jenkins CI + Docker Engine	Internal LB :8080, IAP SSH	Healthy
Game server VM	WorkAdventure (7-container stack)	https://<ip>.sslip.io	Live — 7/7
Game server VM	Cloud-Morph (Go + Wine)	http://<ip>:8080	Live
Database	Cloud SQL MySQL 8.0 (private, CMEK)	Backend tier only	RUNNABLE

Why a dedicated VM instead of the MIG tiers

- Both games are **stateful, single-host** stacks (Traefik sessions, Redis, a Wine container). An autoscaled, round-robin MIG would split state across replicas and wipe it on every roll/auto-heal.
- They require a **stable public IP and inbound 80/443/8080**; the MIG tiers have no public IP and are reachable only through load balancers.
- Isolation preserves the production tiers' posture (no public IP, IAP-only SSH).

Figure 13.1 — Game server architecture



Terraform changes made to accommodate the games

All additions are gated behind `enable_game_server` (off by default) so the core three-tier platform is unaffected when games are not deployed.

Change	What it does / why
New game-server module	Dedicated Compute Engine VM (Shielded, CMEK disk, OS Login) that runs Docker Compose apps; kept separate from the compute/MIG module.
Static external IP	<code>google_compute_address</code> — stable public address needed for DNS (sslip.io) and Let's Encrypt HTTP-01 validation.
Web firewall rule (80, 443)	Allows public HTTP/HTTPS to the VM (tag game-server); WorkAdventure's Traefik terminates TLS.
<code>additional_web_ports</code> variable	Opens extra ports (8080 for Cloud-Morph) without editing the module — set via <code>game_server_extra_ports</code> .
IAP SSH firewall rule	Admin SSH to the VM via IAP range (35.235.240.0/20) only; no public SSH.
<code>enable_game_server</code> toggle	count-based optional deployment; the games add nothing when disabled.
storage + IAP APIs enabled	<code>storage.googleapis.com</code> (audit-bucket agent) and <code>iap.googleapis.com</code> (SSH tunnel) added to <code>project-services</code> .
CMEK disk reuse	The VM's boot disk uses the security module's disk key, consistent with tier hardening.

14. Deployed Game Platforms

14.1 WorkAdventure

WorkAdventure is a web-based virtual world (a 2D metaverse) with proximity audio/video over WebRTC. It was deployed as a multi-container stack via Docker Compose using prebuilt images, fronted by Traefik with automatic TLS.

Container	Role
reverse-proxy (Traefik)	Ingress on 80/443, path-based routing, Let's Encrypt (HTTP-01) TLS termination
play	Serves the game client (HTML/JS/WASM); WebSocket entry point for players
back	Shares room/world state between connected users
map-storage	Serves and edits maps (protected by basic authentication)
uploader	Stores chat file uploads (Redis-backed)
icon	Fetches favicons for websites embedded in iframes
redis	Scripting-API variables and uploader storage

Deploy flow

- The startup script installs Docker, derives the domain as `<ip>.sslip.io` from the instance's external IP, writes an `.env` (DOMAIN, random SECRET_KEY, ACME_EMAIL, map-storage basic-auth) and runs `docker compose up -d`.
- Traefik obtains a Let's Encrypt certificate for the `sslip.io` name via the HTTP-01 challenge on port 80 — hence the need for a real DNS name and open 80.
- Outcome: `https://<ip>.sslip.io` serves the world over valid TLS (verified), so WebRTC audio/video functions.

14.2 Cloud-Morph

Cloud-Morph streams a Windows desktop application to the browser over WebRTC. A Go server handles signaling and streaming while the application itself runs under Wine inside a Docker container. Minesweeper (bundled with the repo) is the smoke-test application.

Component	Role
Go server (:8080)	HTTP + WebRTC signaling; captures the app's video/audio, streams it, relays input
syncwine image	Docker image with Wine + Xvfb + ffmpeg + the input bridge (syncinput.exe)
appvm container	Runs the Windows app (Minesweeper) under Wine, headless on Xvfb display :99
nat1to1ip	WebRTC 1:1 NAT hint set to the VM's public IP so ICE candidates are reachable

Deploy flow

- The repo requires **Go 1.24+**; the official Go toolchain is installed (Debian's 1.19 is too old) and the server is compiled with `go build`.
- The syncwine Wine image is built once; the Go server launches the appvm container and serves the client on `:8080` (opened via `additional_web_ports`).
- Outcome: `http://<ip>:8080` streams Minesweeper (verified). In this smoke test Cloud-Morph is HTTP-only; for production it would also sit behind Traefik/TLS.

15. Deployment Notes & Operational Lessons

Deploying to a real (fresh, quota-limited) project surfaced several issues that were resolved and folded back into the modules. They are recorded here for operability and to inform future environments.

Symptom	Root cause	Resolution
Instances could not fetch packages	No public IP and no NAT	Added Cloud NAT + Cloud Router for controlled egress
Startup scripts failed (exit 127)	CRLF line endings authored on Windows	Strip CR via <code>replace()</code> ; <code>.gitattributes</code> enforces LF
Cloud Armor apply failed	New project SECURITY_POLICIES quota = 0	Cloud Armor made optional (<code>enable_cloud_armor</code>); request quota to enable
Autoscaler apply failed	Regional INSTANCES quota = 8	Right-sized dev autoscaling; request quota to scale
GCS CMEK grant failed	Storage service agent not yet created	Use <code>google_storage_project_service_account</code> data source + ordering
Jenkins never started	apt repo unsigned; package unavailable	Run Jenkins as a Docker container (<code>jenkins/jenkins:its-jdk17</code>)
Backend tier auto-heal looped	Health check hit / (403) while Jenkins serves 8080	Health path <code>/login</code> + longer initial delay
Cloud-Morph build failed	Debian Go 1.19 shadowed required Go 1.24 on PATH	Prepend official Go; purge apt Go; <code>GOTOOLCHAIN=local</code>

Operational access model

- **Terraform auth:** the provider authenticates with a short-lived token from the operator's gcloud session (`GOOGLE_OAUTH_ACCESS_TOKEN`), avoiding long-lived service-account keys.
- **Instance access:** all SSH is via Identity-Aware Proxy TCP forwarding (no public SSH). An `~/.ssh/config` `ProxyCommand` entry enables `ssh <instance>` and VS Code Remote-SSH.
- **Immutability:** MIG instances are ephemeral — durable changes are made to the Terraform templates and rolled, never by mutating live VMs.

Document generated for the modular, hardened, deployed Terraform baseline. Regenerate with `python docs/generate_pdf.py` after infrastructure changes.